



إجراءات التشغيل الأمنية (Security Operating Procedure)

اسم الإجراء
(Procedure Name):

إجراءات التشغيل الأمنية لإدارة التغيير وتحديثات جدران الحماية والشبكة والترقيع
(Firewall, Network Change & Patch Management SOP)

الإصدار (Version)	اعتمد بواسطة (Approved By)	مالك الوثيقة (Owner)	تاريخ آخر تحديث (Date Last Updated)	دورية المراجعة (Review Frequency)	المراجعة القادمة (Next Review)	ملاحظات (Comments)
1.0	م. فهد العتيبي (CIO) بالتنسيق مع إدارة الحربي (CISO)	قسم البنية التحتية والشبكات (إدارة تقنية المعلومات)	سبتمبر 2026 15	سنوية (أو بعد الحوادث الكبرى)	سبتمبر 2027 15	إجراء تشغيلي إلزامي لمعالجة ثغرات إدارة التغيير في جدران الحماية والترقيع وضمان استمرارية الخدمات المصرفية الرقمية

(Confidential) سري: (Classification) التصنيف

1. الغرض (Purpose)

الواجب اتباعها بدقة عند تنفيذ أي تغييرات أو تحديثات على جدران (SOP) تهدف هذه الوثيقة إلى تحديد وتوثيق إجراءات التشغيل الأمنية القياسية (Fortinet FortiWeb) والمبدلات، وجدار حماية تطبيقات الويب (Cisco ASR) والموجهات، (Palo Alto Networks) الحماية الرئيسية وإدارة الترقيع وسد الثغرات في أنظمة بنك الأفق الرقمية. يهدف هذا الإجراء بشكل مباشر إلى القضاء التام على مخاطر الأخطاء البشرية الفردية وضمان عدم تكرار حادثة انقطاع الخدمات المصرفية الرقمية (تطبيق آفاق بلس ومنصة آفاق نت (التي دامت 3 ساعات سابقاً، من خلال فرض ISO/IEC من مواصفة A.5.37 المراجعة الثنائية، وإلزامية وجود خطة تراجع سريعة ومختبرة، وضمان التوافق مع متطلبات الضابط. وتعليمات البنك المركزي السعودي (ساما) 27001:2022

2. النطاق (Scope)

وترقيات (Patches) والرقع الأمنية (Rules) ينطبق هذا الإجراء التشغيلي الأمني على كافة التغييرات المجدولة والطارئة، وتحديثات القواعد والتكوينات المطبقة على البنية التحتية لتكنولوجيا المعلومات والاتصالات في بنك الأفق الرقمية، ويشمل (Firmware) البرامج الثابتة

- جدران الحماية: جدران الحماية المحيطة والداخلية (Palo Alto Networks High Availability Cluster).
- «الحامي لتطبيق» آفاق بلس «ومنصة» آفاق نت (Fortinet FortiWeb WAF) جدار حماية تطبيقات الويب: WAF جدار الويب
- في (Cisco Catalyst Switches) والمبدلات المركزية (Cisco ASR Routers) أجهزة الشبكة: أجهزة التوجيه الرئيسية والفروع المقر الرئيسي وكافة الفروع الـ 25
- الأمن التي تربط المقر الرئيسي بمركز التعافي من الكوارث في جدة والبنك VPN الروابط الشبكية: روابط الاتصال المزدوجة وأنفاق الـ المركزي وشبكة المدفوعات الوطنية
- الخوادم المصرفية: خوادم الإنتاج (40 خادماً في الرياض و10 في جدة (وقواعد بيانات العملاء وأرامل ونظام المعاملات المصرفية الأساسي (Core Banking System).
- الفئات المشمولة: يلزم بهذا الإجراء كافة موظفي قسم البنية التحتية والشبكات، وقسم الدعم والتشغيل، ومهندسي أمن المعلومات، والاستشاريين والمتعاقدين الخارجيين.

3. الأدوار والمسؤوليات (Roles and Responsibilities)

تتوزع المسؤوليات التشغيلية والأمنية لتنفيذ هذا الإجراء على النحو التالي:

- وصياغة القواعد والإعدادات، (RFC) إعداد طلب التغيير: (Network Engineer / Implementer) مهندس الشبكات / المنفذ. وأخذ النسخ الاحتياطية للإعدادات قبل التنفيذ، وتنفيذ التعديل واختباره، (Rollback Plan) المقترحة، وتوثيق خطة التراجع.
- مهندس شبكات أو أمن أول معتمد يتولى مراجعة وتدقيق التغيير: (Peer Reviewer - 4-Eyes) مهندس التدقيق والمراجعة الثانية. المقترح فنياً والتحقق من عدم تأثيره على حركة المرور المصرفية والتحقق من سلامة خطة التراجع والتوقيع بالموافقة الفنية.
- المراجعة الإدارية واعتماد جدولة التغيير ضمن نافذة الصيانة الرسمية: (Infrastructure Manager) مدير البنية التحتية والشبكات. المعتمدة والتنسيق مع الإدارات المعنية.
- ISO تقييم الأثر الأمني للتغيير ومراجعة التوافق مع سياسات البنك ومعايير: (CISO / SecOps Team) فريق حوكمة أمن المعلومات. وضوابط ساما، والموافقة الأمنية على طلبات فتح المنافذ أو تعديل القواعد 27001.
- مراقبة حركة المرور والإنذارات وسجلات الأحداث على مدار الساعة قبل وأثناء وبعد تنفيذ التغيير، والتنبيه: (SOC) مركز العمليات الأمنية. الفوري في حال رصد أي سلوك شاذ أو حظر لحركة المرور المصرح بها.
- التحقق من سلامة وصول المعاملات وتطبيقات العملاء الرقمية (أفاق: (Operations & Helpdesk) إدارة العمليات المصرفية والدعم. بلس وأفاق نت (بعد التنفيذ والإبلاغ عن أي شكاوى فوراً).

4. خطوات الإجراء (Procedure) (Step-by-Step Implementation)

تتبع عملية تعديل إعدادات جدران الحماية وتحديثات الشبكة التسلسل الإلزامي التالي المكون من سبع خطوات تفصيلية:

الخطوة 1: تقديم طلب التغيير والتوثيق المسبق (Step 1: Change Request Initiation):

قبل موعد التنفيذ بـ 72 ساعة (Jira Service Management) عبر نظام إدارة التذاكر (RFC) يقوم مهندس الشبكات بتقديم طلب تغيير رسمي 'Any' والمنافذ المحددة بدقة (مع حظر استخدام IP على الأقل للتغييرات الاعتيادية. يجب أن يتضمن الطلب: مبرر العمل المصرفي، عناوين الـ نهائياً، الأجهزة المتأثرة، نافذة الصيانة المحددة) عادة بين الساعة 2:00 صباحاً و 4:00 صباحاً، والأهم من ذلك خطة تراجع تفصيلية ومكتوبة. توضح كيفية إعادة الإعدادات السابقة خلال 10 دقائق في حال حدوث أي خلل (Rollback Plan).

الخطوة 2: المراجعة الثنائية الإلزامية - مبدأ الأعين الأربع (Step 2: Mandatory Peer Review - 4-Eyes Principle):

يقوم مهندس شبكات ثانٍ مستقل ومؤهل بمراجعة تفاصيل التغيير وقواعد الجدار الناري المقترحة سطرًا بسطر. يتحقق المهندس الثاني من: صحة عناوين المصدر والوجهة، عدم تعارض القاعدة الجديدة مع القواعد الأساسية لخدمات البنك الرقمية (مثل عدم تكرار خطأ حذف قاعدة خوادم التطبيقات المصرفية)، كفاية المبرر الأمني، وواقعية خطة التراجع. لا يمكن تمرير الطلب دون التوقيع الإلكتروني للمراجع الثاني.

الخطوة 3: التقييم والموافقة الأمنية من إدارة أمن المعلومات (Step 3: Information Security Approval):

يتم تقييم مستوى المخاطر السيبرانية المترتبة على فتح المنافذ، والتأكد من (SecOps/CISO) تتم مراجعة الطلب من قبل فريق أمن المعلومات. يتم التحقق من عدم تعطيل أي من WAF، مطابقتها لسياسة التحكم في الوصول وسياسة أمن الشبكات. وفي حال كانت التغييرات تخص جدار الويب. الحماية لتطبيق أفاق بلس OWASP Top 10 قواعد.

الخطوة 4: أخذ النسخ الاحتياطية للإعدادات والتحقق من جاهزية (Step 4: Pre-Change Backup & Validation):

لجدار (Running Configuration) قبل البدء بأي تعديل مباشر، يلتزم المهندس المنفذ بأخذ نسخة احتياطية كاملة من ملف الإعدادات المشغلة كما يتم ('PaloAlto-HQ-Config-PreChange-YYYYMMDD.xml': مثال) الحماية أو الجهاز المعني وحفظها في مستودع آمن ومؤرخ. في وضع الجاهزية التامة لرصد الشبكة (SOC) التحقق من أن خوادم المراقبة ومركز العمليات الأمنية.

الخطوة 5: التنفيذ ضمن نافذة الصيانة المعتمدة (Step 5: Implementation in Maintenance Window):

ومسجل (PAM) يتم تنفيذ التعديل حصرياً خلال نافذة الصيانة المعتمدة عبر حساب إداري فردي موثق ومراقب عبر منصة إدارة الوصول المميز بالكامل. يُحظر إجراء أي تعديلات إضافية خارج النطاق المعتمد في تذكرة التغيير.

الخطوة 6: الفحص والاختبار التشغيلي والأمني للخدمات (Step 6: Post-Change Verification & Testing):

بنجاح، التحقق من أن Core Banking يقوم المنفذ وفريق العمليات بفحص فوري يشمل: التأكد من عمل تطبيق «أفاق بلس» ومنصة «أفاق نت» و» لحركة المرور (Drops) جميع الاتصالات المصرفية تعمل بشكل طبيعي، مراجعة سجلات جدار الحماية للتأكد من عدم وجود حظر غير مقصود المصرفية، والتأكد من استقرار روابط الشبكة بين الرياض وجدة.

الخطوة 7: إجراءات التراجع الفوري عند ظهور أي خلل (Step 7: Immediate Rollback Trigger):

في حال حدوث أي خلل تشغيلي غير متوقع، أو انقطاع في أي خدمة مصرفية، أو تعذر نجاح الاختبار خلال 15 دقيقة من التنفيذ؛ يجب فوراً وبدون أي بإعادة نسخة الإعدادات السابقة المحفوظة في الخطوة 4 بالكامل. يتم إشعار مدير الشبكات «(Rollback) تردد إيقاف التنفيذ وتطبيق «خطة التراجع فوراً وإلغاء التغيير للتحقيق في أسباب الفشل SOC ومدير أمن المعلومات والـ

5. الضوابط الأمنية (Security Controls)

تتضمن الضوابط الأمنية الفنية والتنظيمية المطبقة في هذا الإجراء ما يلي:

- حظر تام لأي تغيير انفرادي على جدران الحماية وأجهزة الشبكة الحيوية: (4-Eyes Principle) **الفحص المزدوج**: مبدأ الأعين الأربع.
- وتسجيل الجلسة بالفيديو MFA مع مصادقة ثنائية PAM إلزامية تسجيل الدخول عبر منصة: (PAM) **التحكم بالوصول**: إدارة الوصول المميز.
- في الواجهة أو المنفذ 'Any' حظر كافة المنافذ افتراضياً، وحظر استخدام خيار: (Implicit Deny) **قواعد الشبكة**: الحظر التلقائي الافتراضي نهائياً.
- **حماية الإعدادات**: النسخ الاحتياطي الإلزامي قبل التنفيذ: لا يُسمح بتعديل أي تكوين دون أرشفة التكوين السابق ألياً والتحقق من إمكانية استرجاعه.
- HTTP و Telnet بشهادات معتمدة مع حظر بروتوكولات HTTPS و SSHv2 **التشفير**: تشفير قنوات الإدارة: استخدام بروتوكول.
- في حال حدوث أي تعديل على إعدادات SOC **كشف التلاعب**: حماية التكوينات ضد التعديل غير المصرح به: تفعيل تنبيهات لحظية ترسل لـ الأجهزة خارج نوافذ الصيانة.

6. إدارة الحوادث (Incident Management)

في حال أدى تنفيذ أي تغيير شبكي أو تحديث إلى انقطاع أو تدهور في الخدمات المصرفية الرقمية أو شكاوى عملاء، يتم تفعيل خطة إدارة الحوادث: وفق المسار التالي (A.5.26 - Incident Response Procedure) وفق الإجراء المعتمد

- إذا أثر على الخدمات المصرفية للعملاء (P1/Critical Incident) **المرحلة 1**: التصنيف والتصعيد: تصنيف الحادث فوراً كحادث حرج خلال 15 دقيقة CIO و CISO وإبلاغ.
- واستعادة آخر إعدادات مستقرة دون تضيق الوقت (Rollback) **المرحلة 2**: التراجع والاستعادة الفورية: البدء الفوري في تطبيق خطة التراجع في التحليل أثناء انقطاع الخدمة.
- **المرحلة 3**: الإخطار والتنسيق: تفعيل خلية إدارة الأزمات وإبلاغ خدمة العملاء لإدارة اتصالات العملاء وإبلاغ البنك المركزي السعودي (ساما) إذا تجاوز الانقطاع الحدود النظامية.
- خلال 24 ساعة (Post-Incident Review) عقد اجتماع مراجعة بعد الحادث: (RCA) **المرحلة 4**: التحقيق الجنائي وتحليل السبب الجذري بمشاركة مهندسي الشبكات والأمن، وجمع السجلات، وتحديد السبب الجذري، وتوثيق الدروس المستفادة خطياً لمنع التكرار.

7. المراقبة والتدقيق (Monitoring and Auditing)

تخضع كافة أنشطة إدارة التغيير والتشغيل الأمني للمراقبة والتدقيق الدوري المستمر:

- ومؤشرات أداء الخوادم NetFlow سجلات جدران الحماية وتدفقات (SOC) المراقبة اللحظية: يراقب مركز العمليات الأمنية: **SOC مراقبة** المصرفية على مدار 24/7 لرصد أي انقطاعات أو هجمات فوراً.
- (Quarterly Firewall Audit) **تدقيق القواعد**: المراجعة الدورية لقواعد الجدار الناري: تقوم إدارة أمن المعلومات بإجراء تدقيق فصلي شامل لكافة القواعد لمسح القواعد المعطلة أو غير المستخدمة أو الزائدة.
- **التدقيق الداخلي**: التدقيق الداخلي: تقوم إدارة المراجعة الداخلية (أ. أحمد الغامدي) (بتدقيق عينات عشوائية من تذاكر التغيير كل 6 أشهر للتحقق من الالتزام بتطبيق المراجعة الثنائية وخطط التراجع وموافقات CISO.
- واختبارات اختراق نصف سنوية للتحقق من عدم تسبب التغييرات Qualys إدارة الثغرات: فحص الثغرات: إجراء مسح ربع سنوي عبر منصة. في نشوء أي ثغرات أمنية جديدة.

8. المراجعة والتحديث (Review and Update)

تتم مراجعة وتحديث هذه الوثيقة بصفة دورية سنوية من قبل قسم البنية التحتية والشبكات بالتعاون مع إدارة أمن المعلومات. كما تخضع الوثيقة للمراجعة والتحديث الفوري غير المجدول في أي من الحالات التالية:

- وقوع أي حادث أمني أو انقطاع تشغيلي جسيم في الشبكة أو الخدمات المصرفية الرقمية.
- إدخال تغييرات هيكلية على البنية التحتية للشبكة أو استبدال جدران الحماية وأنظمة الأمان.
- صدور تحديثات تنظيمية أو متطلبات جديدة من البنك المركزي السعودي (ساما) (أو الهيئة الوطنية للأمن السيبراني).
- صدور توصيات جوهرية من تقارير التدقيق الداخلي أو التدقيق الخارجي لمواصفة ISO/IEC 27001:2022.

9. المراجع والوثائق ذات الصلة (References)

تستند هذه الوثيقة وترتبط بالمعايير والسياسات المعتمدة التالية:

- A.8.32، (أمن الشبكات) A.8.20، (توثيق إجراءات التشغيل) A.5.37: الضوابط – ISO/IEC 27001:2022 المواصفة القياسية الدولية (إدارة التهيئة) A.8.9، (إدارة التغيير).
- (SAMA Cybersecurity Framework) إطار الأمن السيبراني الصادر عن البنك المركزي السعودي.
- (ISMS-DOC-05-4) سياسة أمن المعلومات الشاملة لبنك الأفاق الرقمية.
- (Change & Patch Management Policy) سياسة إدارة التغيير والترقيع الأمني.
- (Network Security Policy) سياسة أمن الشبكات وفصل الأنظمة.
- (Incident Response Procedure - A.5.26) إجراءات الاستجابة لحوادث أمن المعلومات.
- (Palo Alto & FortiWeb Hardening Baseline) دليل إعدادات وخط الأساس لجدران الحماية.